

DRAFTORYN

Product Philosophy, Scope & Cybersecurity Document System

Purpose of this document

This is the canonical product brief for AI systems working on Draftoryn. It explains what Draftoryn is, who it serves, how the product should behave, the cybersecurity document families it must support, and the principles that should govern product decisions.

Core product promise

Create professional cybersecurity documents quickly.

Draftoryn is designed for users who need a strong first draft of a real cybersecurity document without spending excessive time formatting, structuring, or manually composing it. The experience should feel fast, guided, credible, and practical.

Critical constraint

Do not turn Draftoryn into a heavyweight GRC system, project-management platform, security ticketing system, or engagement-management system. The primary job is document creation.

1. Product Definition

Draftoryn is a document-generation platform built initially around cybersecurity. Its job is to help a user go from intent to a polished, usable document in minutes. The user chooses the document they need, provides the relevant information through a focused input experience, reviews the generated result, edits it where necessary, and exports it.

The product should feel like a specialist tool, not a generic AI writing wrapper. Draftoryn must understand the conventions of cybersecurity documentation and use domain-appropriate structure, terminology, risk language, scope boundaries, testing language, evidence expectations, and reporting patterns.

The platform is document-first. A document is the primary unit of value. Any structured data, templates, AI generation, or export logic exists to produce a better document faster.

The product should support both human-facing and machine-readable outputs. Human users need polished documents; AI systems and automation workflows benefit from structured representations of the same content.

2. Product Philosophy

2.1 Speed over ceremony

The dominant user motivation is speed. Users are not expected to spend an hour configuring a complex workspace before they can create a document. The shortest path to a useful result is the default.

- A user should understand what to do immediately after opening Draftoryn.
- Document selection should be obvious and grouped by cybersecurity task.
- Questions should be limited to information that materially improves the document.
- Defaults should be sensible and editable rather than forcing users to configure everything.
- The first generated draft should be useful even when the user provides imperfect input.

2.2 Quality over generic fluency

Draftoryn is not successful merely because its text sounds polished. The generated document must be structurally credible and appropriate for the cybersecurity context. Terminology, section order, scope boundaries, roles, assumptions, limitations, and reporting expectations need to make sense for the selected document type.

2.3 Guided input, not giant prompts

Do not force users to write a prompt such as “write me a penetration testing agreement.” Draftoryn should ask targeted questions and transform answers into a coherent document. The system should feel like a guided drafting assistant rather than a blank chat box.

2.4 AI drafts; humans remain in control

The output is a professional draft, not an unreviewable legal or technical authority. Users should be able to edit content freely, regenerate selected sections, insert or remove sections, and override AI suggestions. Draftoryn should make it easy to review and correct the document before use.

2.5 Documents should be usable outside Draftoryn

Exports are a core part of the product, not an afterthought. A user should be able to take the result and use it immediately in a client engagement, internal assessment, project, report, policy, or AI workflow.

2.6 Structured output matters

Where the document type supports it, Draftoryn should preserve the semantic structure behind the prose. JSON and XML are first-class machine-readable outputs. Markdown and YAML may also be supported where useful. The purpose is not to wrap prose in braces; the purpose is to represent meaningful fields and relationships.

2.7 Professional by default

Documents should look like something a real security consultant, internal security team, auditor, assessor, or engineering organization could use. Typography, spacing, headings, tables, metadata, page structure, and terminology should be deliberate.

3. Core User Experience

Default flow: Choose a document -> answer focused questions -> generate -> review/edit -> export.

This flow should remain the center of the application even as the catalog becomes large.

Stage	User experience	Product responsibility
1. Discover	User quickly identifies the type of cybersecurity document needed.	Clear taxonomy, search, categories, examples, and sensible naming.
2. Input	User answers concise, context-relevant questions.	Collect only high-value information; explain fields when needed.
3. Generate	User receives a coherent first draft.	Apply document-specific structure, tone, terminology, and consistency.
4. Review	User edits, regenerates sections, or adjusts details.	Never make the user fight the AI or rebuild the document manually.
5. Export	User downloads/uses the document.	Produce clean human-readable and structured machine-readable outputs.

4. Cybersecurity Document Scope - Day One

Draftoryn should support the full cybersecurity-oriented catalog below from the initial product release. These are the product categories and document types that define the launch scope.

A. Penetration Testing

- Penetration Testing Agreement
- Penetration Testing Statement of Work (SOW)
- Authorization to Test / Authorization Letter
- Penetration Test Scope Document
- Rules of Engagement (RoE)
- Testing Schedule / Maintenance Window
- Communication & Escalation Plan
- Testing Restrictions / Prohibited Activities

- Data Handling & Evidence Requirements
- Reporting Requirements
- Penetration Test Report
- Executive Penetration Test Summary
- Technical Findings Report
- Remediation Recommendations
- Retest Authorization
- Retest Report

B. Red Team / Adversary Emulation

- Red Team Statement of Work
- Red Team Authorization
- Red Team Scope & Target Definition
- Red Team Rules of Engagement
- Campaign Objectives
- Threat Actor Profile
- Adversary Emulation Plan
- Attack Scenarios
- Constraints / Prohibited Actions
- Communications & Emergency Abort Procedures
- Detection / SOC Coordination Requirements
- Evidence Collection Requirements
- Red Team Report
- Red Team Executive Summary
- Attack Narrative / Timeline
- Red Team Findings
- Detection & Response Assessment
- Remediation Recommendations
- Retest / Validation Report

C. Vulnerability Assessment

- Vulnerability Assessment Statement of Work
- Assessment Authorization
- Assessment Scope & Asset Inventory
- Assessment Methodology
- Assessment Schedule
- Testing Constraints
- Vulnerability Severity Model
- Vulnerability Findings Report
- Vulnerability Executive Summary
- Technical Vulnerability Report
- Remediation Plan
- Validation / Retest Report

D. Security Assessment

- Security Assessment Plan
- Security Assessment Scope
- Assessment Authorization
- Security Assessment Methodology
- Security Requirements for Assessment
- Evidence Requirements
- Assessment Criteria
- Risk Rating Methodology
- Security Assessment Findings
- Risk Register
- Remediation Plan
- Final Security Assessment Report
- Security Assessment Executive Summary
- Assessment Sign-off

E. Cloud Security Assessment

- Cloud Security Assessment Statement of Work
- Cloud Assessment Authorization
- Cloud Environment Scope
- Account / Subscription / Project Inventory
- Cloud Assessment Methodology
- Cloud Configuration Requirements
- Identity & Access Review
- Network Security Review
- Data Security Review
- Logging / Monitoring Review
- Cloud Security Findings
- Cloud Risk Assessment
- Cloud Remediation Plan
- Final Cloud Security Assessment Report
- Cloud Retest / Validation Report

F. Security Architecture Review

- Architecture Review Statement of Work
- Architecture Review Scope
- System / Application Description
- Architecture Documentation Requirements
- Security Objectives
- Trust Boundary Description
- Threat Model for Architecture Review
- Architecture Review Criteria
- Architecture Findings

- Architecture Risk Assessment
- Security Recommendations
- Security Architecture Review Report
- Architecture Review Sign-off

G. Threat Modeling

- Threat Modeling Scope
- System Description
- Asset Inventory
- Actor Inventory
- Trust Boundaries
- Data Flow Description
- Entry Point Inventory
- Threat Catalogue
- Attack Scenarios
- Threat Risk Assessment
- Mitigations
- Residual Risk Assessment
- Threat Model Report
- Threat Model Review / Sign-off

H. Digital Forensics

- Forensics Engagement Agreement
- Forensics Authorization
- Investigation Scope
- Evidence Collection Plan
- Evidence Handling Procedure
- Chain of Custody Record
- Acquisition Plan
- Forensic Examination Methodology
- Investigation Timeline
- Evidence Register
- Forensic Findings
- Forensic Analysis Report
- Forensic Executive Summary
- Forensic Conclusions / Recommendations

I. Incident Response

- Incident Response Plan
- Incident Classification Matrix
- Incident Response Roles & Responsibilities
- Contact / Escalation Matrix
- Incident Communications Plan
- Incident Triage Procedure

- Containment Procedure
- Eradication Procedure
- Recovery Procedure
- Evidence Preservation Procedure
- Incident Record
- Incident Timeline
- Incident Report
- Post-Incident Review
- Lessons Learned
- Corrective Action Plan

J. Vulnerability Disclosure

- Vulnerability Disclosure Policy
- Vulnerability Reporting Procedure
- Disclosure Scope
- Eligible Assets
- Out-of-Scope Activities
- Researcher Rules
- Safe Harbor Terms
- Severity Classification
- Response SLA
- Coordinated Disclosure Procedure
- Vulnerability Report Template
- Researcher Communication Templates

K. Bug Bounty Program

- Bug Bounty Program Policy
- Program Scope
- In-Scope Assets
- Out-of-Scope Assets
- Program Rules
- Submission Requirements
- Severity / Reward Matrix
- Safe Harbor
- Disclosure Policy
- Triage Procedure
- Duplicate Handling
- Researcher Communication Templates

L. Secure Development / Security Requirements

- Security Requirements Specification
- Secure Development Requirements
- Authentication Requirements
- Authorization Requirements

- Cryptography Requirements
- Logging & Monitoring Requirements
- Data Protection Requirements
- Security Acceptance Criteria
- Security Test Requirements
- Security Architecture Requirements

5. Common Information Model

Although users mostly care about finished documents, the generation system should use a consistent internal representation. This improves quality, consistency, editing, and structured exports. The model should be reusable across cybersecurity document types without forcing every document to expose every field.

Entity / concept	Typical meaning	Examples
Organization	Client, tester organization, vendor, program owner, affected organization.	Company name, department, business unit
People / roles	Named participants and responsibilities.	Tester, client contact, incident commander, SOC lead
Objective	What the activity is intended to establish or accomplish.	Identify exploitable vulnerabilities; evaluate detection
Scope	What is included, excluded, or conditionally included.	Domains, IP ranges, cloud accounts, applications
Schedule	When the activity or response can occur.	Start/end dates, maintenance window
Authorization	Who permits the activity and under what conditions.	Authorized tester, sign-off, authorization date
Constraints	Actions that are restricted, prohibited, or require approval.	No DoS, no destructive actions, stop conditions
Methodology	How the activity is performed or assessed.	Manual testing, evidence review, threat modeling
Evidence	Artifacts supporting assessment conclusions.	Screenshots, logs, hashes, notes
Threat / risk / finding	Security issues and how they are characterized.	Severity, likelihood, impact, affected asset
Recommendation / action	What should be changed or done next.	Remediation, mitigation, validation
Reporting	Expected deliverables, audience, structure, and timing.	Executive report, technical appendix

6. Document Generation Rules

Every document type should have a document-specific generation profile. The generation engine should not produce a generic essay and then rename the heading.

- Use a known section architecture for the selected document type.
- Use domain terminology appropriate to the document and audience.
- Keep facts consistent across the document; the same target should not appear under conflicting names or scopes.

- Distinguish confirmed facts, user assumptions, and AI-suggested content where the difference matters.
- Never invent operational details such as IP addresses, credentials, authorization dates, contacts, legal terms, or testing windows.
- Use placeholders where required information is missing instead of fabricating it.
- Make assumptions visible when assumptions materially affect interpretation.
- Keep sensitive content out of examples and sample defaults unless the user explicitly provides it.
- Use a professional, neutral, precise tone unless the document type calls for a different voice.
- Preserve document hierarchy in all output formats, including machine-readable exports.

7. Review and Editing Philosophy

The generated draft is the beginning of the editing experience, not the end of it. A user should be able to fix the document without restarting the entire generation process.

- Edit any text directly.
- Regenerate one section without rewriting unrelated sections.
- Add a new section from the document type library.
- Delete or hide sections that are unnecessary.
- Change tone or audience where supported.
- Update a source field and propagate the correction through dependent content.
- Preview the final exported layout before downloading.

8. Template and Content System

Templates are a major quality mechanism. A template is not simply a PDF-like layout with placeholders. It should define document structure, section rules, field mappings, guidance, conditional sections, and output formatting.

- Every supported document type should have an explicit canonical structure.
- Sections may be required, optional, or conditional.
- Templates should encode terminology and content guidance appropriate to their document type.
- The system should support organization-specific or user-specific customization later in the product lifecycle, but the default templates must already be strong.
- Template changes should not silently corrupt machine-readable exports.

9. AI-Native Output

Draftoryn must treat structured exports as part of the product, especially JSON and XML. These outputs are intended for AI systems, automation, integrations, and downstream processing.

The structured representation should encode semantics, not merely mirror the visual document.

Example conceptually:

```
{
  "document_type": "penetration_test_engagement",
  "client": { "name": "Example Corp" },
  "scope": { "targets": ["app.example.com"], "out_of_scope": ["production-payment-api"] },
  "rules_of_engagement": { "prohibited": ["denial_of_service"] },
}
```

```
"reporting": {"deliverables": ["executive_summary", "technical_report"]}
}
```

A downstream AI system should be able to understand the document as data: what the engagement is, who is involved, what is in scope, what constraints apply, what findings exist, and what outputs are expected.

10. Output Formats

Format	Primary purpose	Priority
PDF	Professional final document for sharing, submission, or archival use.	Core
DOCX	Editable professional document for users who need Word-compatible output.	Core
Markdown	Portable text, developer-friendly documentation, version control, AI context.	Core
JSON	Structured semantic representation for AI systems and automation.	Core
XML	Structured interoperability and machine-readable document representation.	Core
YAML	Human-friendly structured representation where useful for technical workflows.	Useful
HTML	Web viewing and portable digital rendering.	Useful

11. Primary Users

- Independent penetration testers and security consultants who need client-ready engagement and reporting documents quickly.
- Red team practitioners who need structured engagement, campaign, and reporting documentation.
- Security teams conducting internal assessments and reviews.
- Security engineers and architects producing threat models, architecture reviews, and security requirements.
- Incident-response and forensic practitioners producing plans, records, evidence documentation, and reports.
- Organizations operating vulnerability disclosure or bug bounty programs.

The product should be useful to a single practitioner. It should not assume that the user belongs to a large enterprise, has a dedicated GRC department, or wants to configure an elaborate organizational workspace.

12. Explicit Non-Goals for the Initial Product

These boundaries are important. They prevent the product from drifting away from the core value proposition.

- Do not make document creation dependent on a complicated project or engagement-management workflow.
- Do not require users to maintain a full asset database before they can generate a document.
- Do not position Draftoryn as legal counsel or guarantee legal validity of agreements.

- Do not fabricate legal clauses, authorization facts, testing details, or operational data.
- Do not turn the primary experience into a conversational chatbot where the user must discover the right prompt.
- Do not require users to understand cybersecurity frameworks before they can create basic documents.
- Do not optimize for document quantity at the expense of quality and usability.
- Do not treat cybersecurity terminology as decoration; it should influence structure and content.

13. Quality Bar

Dimension	Expectation
Correctness	The document reflects the user-provided facts and does not invent critical details.
Completeness	The generated result contains the major sections expected for the selected document type.
Consistency	Names, dates, scope, severity, terminology, and other repeated facts remain synchronized.
Professionalism	Formatting and language are appropriate for real-world use.
Editability	Users can easily correct the result without restarting the entire process.
Portability	The document remains usable outside Draftoryn.
Machine readability	JSON/XML preserve meaningful semantic structure rather than unstructured prose.
Safety	The system avoids exposing or inventing sensitive details and clearly handles missing information.
Speed	A competent user should be able to reach a usable first draft quickly.

14. Representative User Scenarios

Scenario	Expected experience
A pentester needs a client-ready agreement	Select Penetration Testing -> answer client, targets, dates, authorization, constraints, deliverables -> generate -> edit -> export PDF/DOCX.
A red teamer needs a campaign package	Select Red Team -> provide objectives, threat profile, targets, restrictions, communications, detection expectations -> generate the appropriate engagement and reporting documents.
A security architect needs a threat model	Select Threat Modeling -> provide system, assets, actors, trust boundaries, data flows, threats, mitigations -> generate a structured threat model with machine-readable output.
An organization needs an incident response document	Select Incident Response -> choose the needed artifact -> provide organization-specific details -> generate, review, and export.
A security team wants a machine-readable specification	Generate the desired cybersecurity document -> export JSON/XML -> feed the structured representation into an AI or internal automation system.

15. Product Decision Rules for AI Agents

When making product, UX, architecture, content, or implementation decisions for Draftoryn, use these rules in order:

1. Optimize for fast creation of a real document.

2. Preserve cybersecurity specificity and credibility.
3. Prefer guided inputs over blank prompts.
4. Keep the interface simple even when the underlying document model is sophisticated.
5. Never invent missing critical facts.
6. Keep human review and editing easy.
7. Generate professional documents by default.
8. Preserve semantic structure for JSON/XML and other machine-readable formats.
9. Treat each document type as a real schema/template, not a generic writing request.
10. Keep the product centered on document creation rather than expanding the user workflow unnecessarily.

16. Canonical One-Paragraph Definition

Draftoryn is a fast, specialist document-generation platform for cybersecurity. Users select the cybersecurity document they need, answer a focused set of questions, and receive a professional first draft that they can review, edit, and export. The platform supports a broad day-one cybersecurity document catalog covering penetration testing, red teaming/adversary emulation, vulnerability assessment, security assessment, cloud security assessment, security architecture review, threat modeling, digital forensics, incident response, vulnerability disclosure, bug bounty programs, and secure-development security requirements. Draftoryn should prioritize speed, cybersecurity-specific quality, guided input, human review, professional formatting, and portability. It must support human-facing exports such as PDF, DOCX, and Markdown as well as machine-readable representations such as JSON and XML, with structured semantics rather than merely wrapping prose in markup. The product is intentionally document-first: its purpose is to help users produce high-quality cybersecurity documents quickly, not to force them into a complex GRC, project-management, or engagement-management workflow.

This document is intended to be treated as the product-philosophy source of truth for AI-assisted work on Draftoryn. When implementation choices conflict with this brief, favor the core principles: fast, specialist, document-first, professional, editable, and AI-readable.